Information Security & ISO-27001 Implementation Manual

Technical Cybersecurity Baseline for Sovereign Cloud Infrastructure in Iraq

SECURITY CONTROL SPECIFICATION:

â¢ Document Reference: IDG-SEC-ISO-27001
â¢ Compliance Baseline: ISO/IEC 27001:2022 & NIST SP 800-207 (Zero Trust)
â¢ Security Classification: RESTRICTED SOVEREIGN DEFENSE

1. Access Control & Identity Governance (A.9 / A.8)

â¢ Phishing-resistant FIDO2 / WebAuthn hardware security keys required for all admin access.
â¢ Role-Based Access Control (RBAC) enforced with Least Privilege principle.
â¢ Automatic session revocation after 15 minutes of administrative inactivity.

2. Cryptography & Data Protection Standards (A.10)

â¢ AES-256-GCM enforced across all relational and object databases at rest.
â¢ TLS 1.3 with forward secrecy enforced across all inter-service and external connections.
â¢ Automatic cryptographic key rotation scheduled every 90 days via sovereign HSM.

3. Security Incident Management & Rapid Triage (A.16)

The IDG Security Operations Center (SOC) operates 24/7/365 continuous monitoring:

â¢ Severity 1 (Critical Sovereign Intrusion): Response and air-gap isolation < 15 minutes.

â¢ Severity 2 (Service Disruption / DDoS): Mitigation and traffic rerouting < 30 minutes.

â¢ Severity 3 (Policy Anomaly / Unapproved Auth Attempt): Audit and forensics < 60 minutes.

4. Continuous Vulnerability Management (A.12)

â¢ Automated dynamic and static application security testing (DAST / SAST) in CI/CD pipeline.

â¢ Mandatory third-party sovereign penetration testing conducted every semi-annual cycle.

â¢ Strict zero-day patch window: Maximum 24 hours for critical CVE vulnerabilities.

AUDIT & CERTIFICATION COMPLIANCE:

[CERTIFIED] Lead Cybersecurity Architect - ISO/IEC 27001:2022 Certified Auditor

[APPROVED] Directorate of Defense & Sovereign Networks - IDG Group